Blacksheep

POLICY DOCUMENT

Security Policy

Blacksheep Operations Pty Ltd & Flux Interactive Pty Ltd

Parties	Blacksheep Operations Pty Ltd & Flux Interactive Pty Ltd
Classification	Internal
Review Cycle	Annually, or following any security incident
Owner	Samuel Thompson-Kennedy
Last Reviewed	10 April 2026

1. Purpose

This policy is jointly adopted by Blacksheep Operations Pty Ltd ("Blacksheep") and Flux Interactive Pty Ltd ("Flux"). It defines the information technology security controls, responsibilities, and practices governing the Blacksheep platform. Flux owns and operates the underlying infrastructure; Blacksheep is the principal service operator and owner of all data processed by the platform. This policy applies to all personnel of either party authorised to access Blacksheep systems, infrastructure, source code, or data.

2. Scope

This policy covers:

- All Blacksheep environments (production, development, local, and any other active environments)
- Source code repositories and CI/CD pipelines
- Infrastructure services (Appendix A — Infrastructure Providers)
- Third-party service integrations
- Any systems or devices used to access the above

3. Personnel & Access

3.1 AUTHORISED PERSONNEL

Access to Blacksheep infrastructure is limited to Flux staff who are authorised to operate on the Blacksheep project. No third parties have access to production systems unless explicitly authorised by Blacksheep and Flux.

3.2 ACCESS CONTROL

- Personnel are granted the minimum access necessary for their role.
- Access to infrastructure does not imply access to production secret material.
- Production secrets are displayed once at generation and are thereafter stored only in the sealed secrets manager, from which they cannot be retrieved in plaintext.
- Only senior engineering, in consultation with Blacksheep, may generate or rotate production secrets.

3.3 ACCESS PROVISIONING & REVOCATION

- Access is provisioned on a per-need basis and is limited to core Flux staff authorised to work on Blacksheep.
- Upon departure or role change, all access credentials, repository permissions, and infrastructure access must be revoked within 24 hours.
- Provisioning and revocation of access requires formal approval by the Blacksheep founder (or delegated senior engineering) and is recorded against the individual's role.

3.4 ONBOARDING REQUIREMENTS

Before access is granted, personnel must:

- Execute a confidentiality agreement covering Blacksheep code, infrastructure, and data.
- Review and acknowledge this policy and the Sensitive Data Policy.
- Confirm that the device used to access Blacksheep systems meets baseline security requirements — full-disk encryption, automatic screen lock, a current operating system, and no unauthorised software.

---

4. Infrastructure Security

4.1 HOSTING

All persistent Blacksheep data — including databases, backups, and logs — is stored within the primary infrastructure provider (see Appendix A). Content may be served globally via edge and CDN networks.

For a full list of infrastructure providers, see **Appendix A**.

4.2 ENCRYPTION

LAYER	MECHANISM
Data at rest	Encrypted by the underlying infrastructure provider (provider-managed encryption)
Cryptographic keys	Sealed and signed via a dedicated key management service; not stored in application code or environment variables
Secrets	Managed via the infrastructure provider's sealed secrets manager; irrevocably sealed at rest

4.3 BACKUP & RECOVERY

Automated backups are managed by the primary infrastructure provider on the following schedule:

FREQUENCY	INTERVAL	RETENTION
Daily	Every 24 hours	6 days
Weekly	Every 7 days	1 month
Monthly	Every 30 days	3 months

Recovery can be initiated by authorised personnel via the infrastructure provider's management interface. All source code is stored in a private version-controlled repository with full history.

---

5. Secure Development Practices

- All code changes require peer review via pull request before merge.
- CI/CD pipelines run automated linting, type checking, and test suites across all environments.
- Production deployments are triggered via CI/CD — not manually.
- Database migrations are version-controlled and applied through the CI/CD pipeline.
- Dependencies are pinned via lock files to prevent supply chain drift.
- Dependencies are monitored for known vulnerabilities via automated tooling, with critical and high-severity issues triaged and patched on a prioritised basis.
- Infrastructure and application components are kept current with security updates released by upstream providers.
- No production secrets are committed to source control.

---

6. Change Management

- All changes follow a branch-based workflow across environments (e.g., development, staging, production).
- Infrastructure configuration changes are restricted to authorised personnel.
- Changes to production secrets follow the process outlined in Section 3.2.

---

7. Monitoring & Logging

Application and infrastructure logs are stored within the primary infrastructure provider for 90 days.

---

8. Incident Response

8.1 RESPONSE PROCEDURE

In the event of a suspected or confirmed security incident:

1. **Detect** — Identify the incident via monitoring, alerts, or manual discovery.
2. **Contain** — Isolate affected systems and revoke any compromised credentials.
3. **Assess** — Determine scope, impact, and root cause.
4. **Remediate** — Apply fixes, rotate affected secrets, and deploy patches.
5. **Communicate** — Ensure both Blacksheep and Flux are aware of the incident and alert relevant stakeholders. If user data is affected, engage Blacksheep's compliance team for regulatory reporting obligations.
6. **Review** — Conduct a post-incident review and update this policy if necessary.

Where a security incident triggers regulatory obligations, Blacksheep and Flux will coordinate to ensure those obligations are met; see the Sensitive Data Policy, Section 8, for breach notification procedures.

8.2 INCIDENT HISTORY

As of the last review of this policy, there have been no security incidents or near-misses.

---

9. Policy Review

This policy is reviewed annually or immediately following:

- A security incident
- A significant change to infrastructure or architecture
- A change in personnel with infrastructure access
- A request from either party or a regulatory body